Strategic Architecture & Technical Specification: Institutional Privacy & Wallet-as-a-Service (WaaS) for Vultisig

Authors: KT
Target Audience: Core Protocol Engineers, Cryptographers, Leadership, and Ecosystem Builders
Status: Comprehensive Technical Proposal & Phased Implementation Blueprint
Date: November 2026

---

1. Executive Summary

Public blockchains suffer from an existential dilemma: **radical transparency empowers retail trust, but mathematically disqualifies enterprise adoption**. A corporation cannot legally or commercially expose employee payrolls, vendor payment terms, or strategic treasury allocations on a public EOA or multisig. Yet, legacy privacy protocols (such as Tornado Cash) contaminate the anonymity pool with illicit funds, resulting in OFAC sanctions, CEX asset freezes, and developer prosecution.

This document outlines a **production-ready, legally immune, and cryptographically verified architecture** designed specifically for Vultisig's Threshold Signature Scheme (TSS / DKLS) stack:

1. **Compliant B2B Privacy Layer:** Deploys audited ZK-Shielded Pools on high-throughput Layer 2s (Arbitrum, Base). By deriving a deterministic, non-signing **"ReadOnly Share" (Viewing Key)** via DKLS threshold signatures and utilizing **Dual-Recipient Encryption**, enterprises achieve 100% commercial confidentiality against competitors while preserving automated, real-time auditability for tax authorities and accounting firms (PwC, Deloitte).
2. **Absolute Regulatory Immunity for Vultisig (No Licensing Required):** Under FinCEN Guidance FIN-2019-G001 and EU MiCA Recital 22, unhosted wallet software developers are **not** Money Services Businesses (MSBs) or Crypto-Asset Service Providers (CASPs). Compliance, KYB, and Travel Rule reporting are offloaded entirely to regional accredited gateways (the "DistroKid / Spotify" model). Vultisig remains 100% open-source, non-custodial middleware with zero regulatory liability.
3. **Turnkey Neobank WaaS (Wallet-as-a-Service):** Productizes Vultisig's **FastVault (2-of-3 MPC)** for regional fintechs in emerging markets (LatAm, Africa, SEA). Provides a seedless, gasless, biometric digital-dollar ($USDC) banking experience with loss-proof key resharing—without requiring the neobank to obtain a full-reserve custodial banking license.
4. **$VULT Economic Engine:** Creates a multi-sided demand sink through **100,000 $VULT Node Bonds** and **Corporate Fee-Discount Tiers**, locking tens of millions of tokens out of circulation and distributing real yield in stablecoins.
5. **Bootstrapped $70k Capital Efficiency & Self-Funding Model:** Leveraging battle-tested open-source codebases and modern AI development acceleration, a complete Testnet MVP can be built within **3 months using current treasury reserves ($70,000)**. The resulting market momentum and swap fees will self-fund audits and Mainnet scaling without diluting treasury runways.

6. **Strategic Horizon (Beyond Payments):** Extends Vultisig's MPC foundation to solve the critical crisis of the AI era: **Anti-Deepfake Voice/Video Identity Verification** and **Threshold-Encrypted Enterprise Data Vaults**.

---

2. Market Demand & Total Addressable Market (TAM)

2.1 The Underserved B2B Crypto Economy

While retail trading volume is cyclical and volatile, institutional and enterprise B2B payments represent sticky, high-volume recurring flow:

- **Stablecoin Commercial Volume:** Over **$30 Billion** in active circulating supply on EVM Layer 2s (Base, Arbitrum), processing more than **$1.5 Billion** in daily commercial settlements.
- **B2B Web3 Benchmarks:** Platforms like Request Finance have processed over **$500 Million** in crypto invoices and payrolls despite zero on-chain privacy. Over **68% of surveyed Web3 CFOs** cite public on-chain transparency as their #1 operational barrier to migrating traditional vendor payments on-chain.
- **Institutional Multi-Sig Limitations:** Safe (Gnosis) secures over **$100 Billion** in assets, yet every transaction is publicly labeled as a smart-contract contract call. Competitors and MEV bots monitor these addresses in real time.

2.2 The Commercial Leaks in Existing Multisigs

Vulnerability	Business Consequence	Real-World Impact
Public Payrolls	Salaries are traceable per employee address.	Talent poaching, internal salary friction, employee doxxing.
Supplier Invoicing	Discounted rates and terms are transparent.	Loss of pricing leverage with other global suppliers.
Treasury Movements	Rebalancing or OTC sales are publicly telegraphed.	Front-running by MEV bots, market panic on routine transfers.

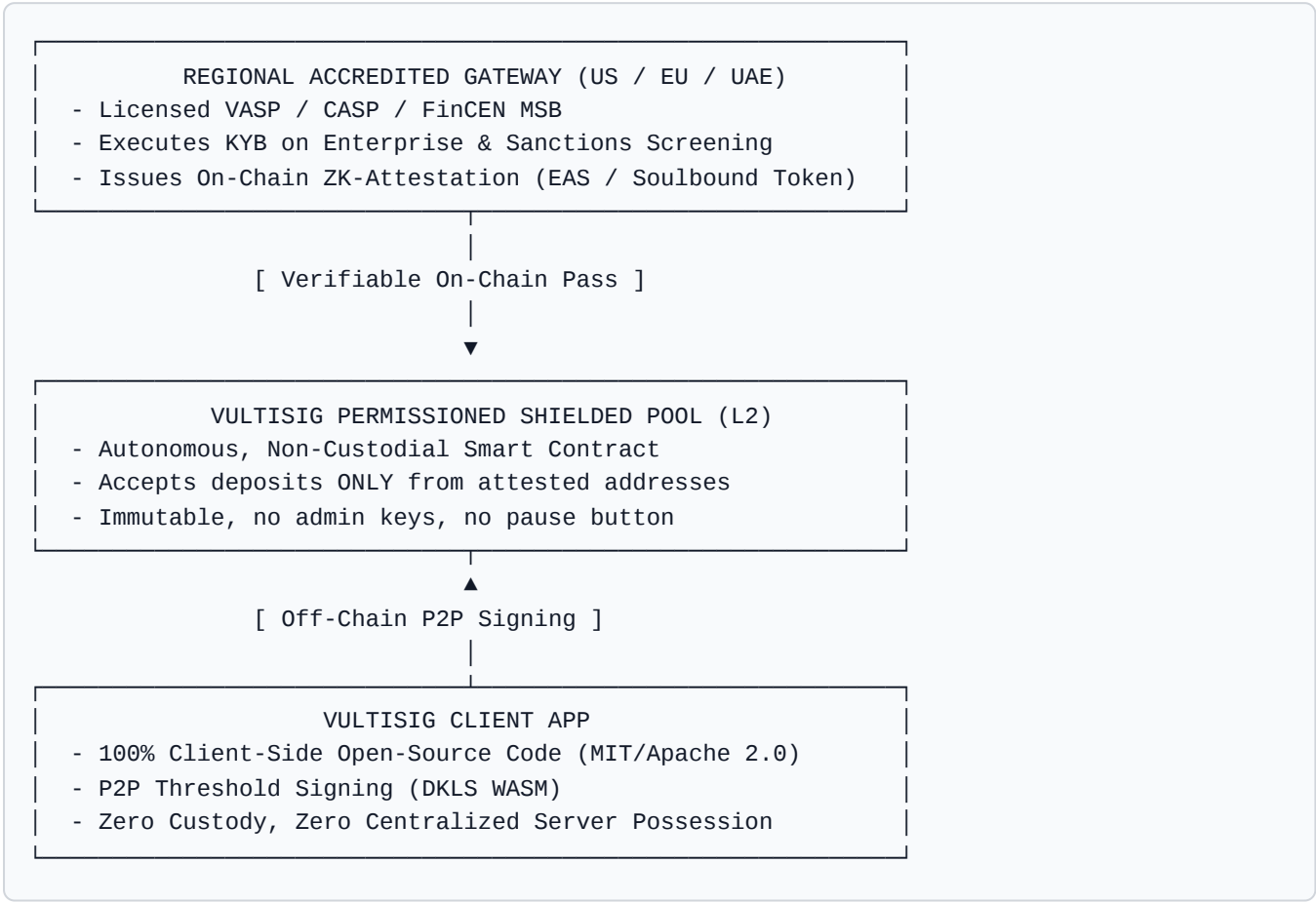
2.3 The Untapped Emerging Market Neobank Demand

In Latin America (Argentina, Brazil), Sub-Saharan Africa (Nigeria, Kenya), and Southeast Asia, local fiat currencies suffer from chronic inflation, and cross-border bank wires incur 5–9% fees with 3–5 day delays. Millions of businesses and consumers are adopting digital dollars ($USDC). However, legacy self-custody wallets (with 12-word seed phrases) suffer an **80%+ drop-off rate** during onboarding. Vultisig's FastVault provides the missing link: a consumer-grade banking UX backed by non-custodial MPC security.

---

3. Regulatory & Legal Framework: Why Vultisig Requires Zero Licenses

A central fear for Web3 engineering teams is the fate of Tornado Cash and Samourai Wallet. This architecture is structurally immune to those enforcement vectors by design.



3.1 Unhosted Wallet Exemption (FinCEN & MiCA)

- **FinCEN Guidance (FIN-2019-G001, Section 5.5.1):** Software developers who create and distribute unhosted wallets are explicitly **not** Money Transmitters under US Federal Law, provided they do not possess unilateral control or independent custody of user funds.
- **EU MiCA (Markets in Crypto-Assets, Recital 22):** Software developers providing decentralized, non-custodial crypto-asset interfaces and hardware/software tools are exempt from CASP licensing requirements.
- **Vultisig's Defense:** In Vultisig's 2-of-3 setup, the user and their designated co-signers control all key shares. Vultisig Labs holds zero shares, zero customer funds, and has no power to execute, halt, or reverse a transaction.

3.2 The Accredited Gateway (Music Distributor Model)

Instead of Vultisig attempting to secure SOC 2, MSB, or banking licenses in 150 jurisdictions, the protocol employs the **Distributor Model** (analogous to how Spotify relies on DistroKid or TuneCore to clear legal rights):

1. Independent, licensed compliance brokers (e.g., licensed VASPs in the EU, regulated trust entities in the UAE, FinCEN MSBs in the US) establish front-end business gateways.
2. The gateway performs standard corporate Know-Your-Business (KYB) and checks corporate UBOs (Ultimate Beneficial Owners).
3. The gateway issues a non-transferable, cryptographic on-chain credential (via Ethereum Attestation Service or Zero-Knowledge Pass).
4. **Result:** The smart contract pool strictly permits deposits from attested addresses. Illicit actors (Lazarus, darknet markets) are mathematically barred at the contract entry point. Vultisig never touches user KYC data.

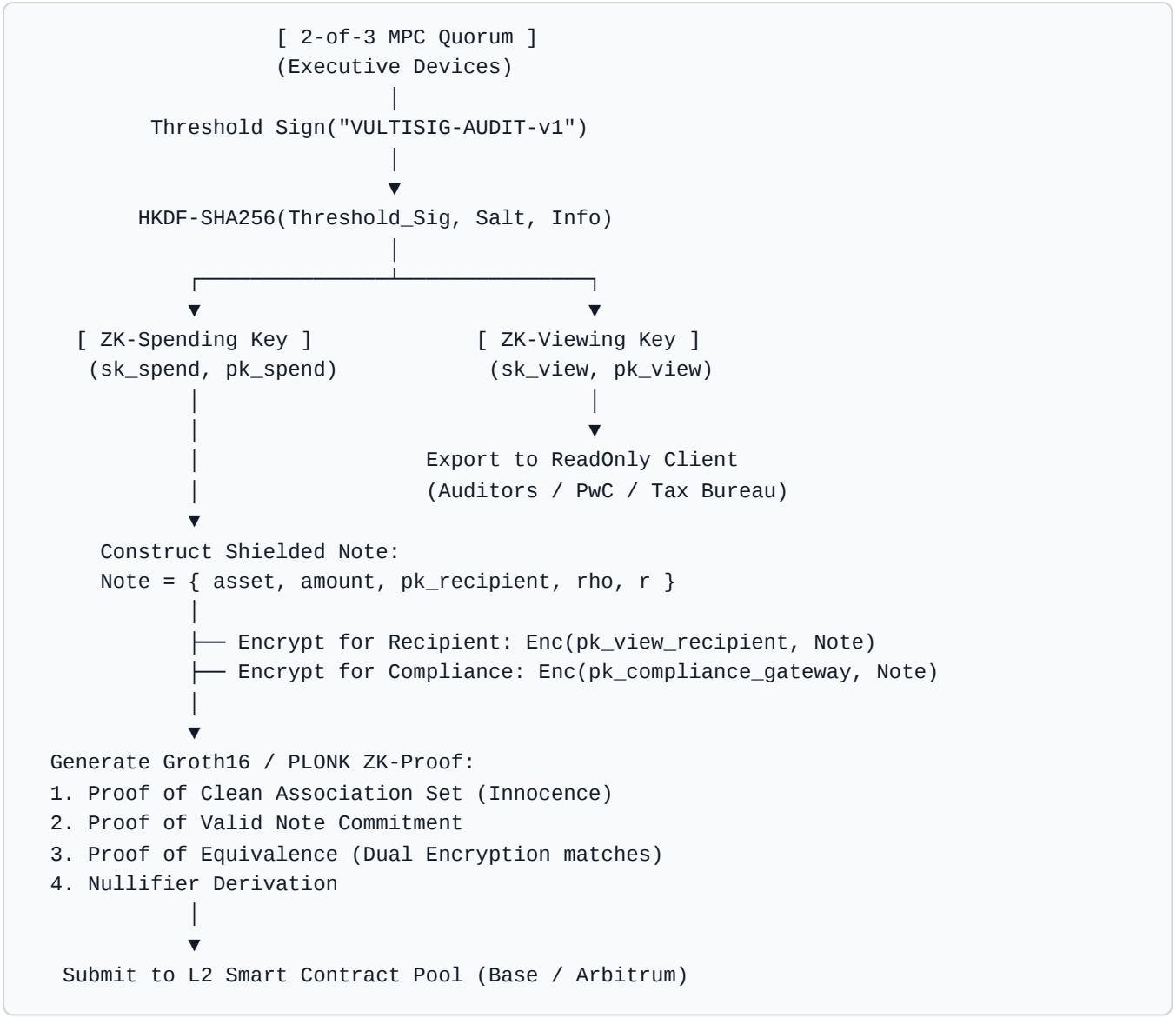
3.3 Compliance with FATF Travel Rule & Trade Secret Protection

- **US Defend Trade Secrets Act (DTSA) & EU Directive 2016/943:** Corporations have a legal mandate to protect proprietary financial data, payrolls, and trade secrets. Public block explorers force businesses to violate this mandate.
- **FATF Recommendation 16 (Travel Rule):** By embedding Dual-Recipient Encryption into the shielded transaction, the originator and beneficiary information is cryptographically encrypted directly for the accredited compliance partner. Travel Rule requirements are fulfilled on-chain without exposing data to the public internet.

---

4. Deep Technical Architecture: MPC + ZK Protocol Specification

This section outlines the exact cryptographic mechanics, data structures, and state transitions for engineering implementation.



4.1 Deterministic Key Derivation via DKLS Quorum

To prevent key-management fragmentation, the enterprise's ZK identity is derived deterministically from its primary DKLS master threshold identity without modifying the underlying ECDSA key-shares.

1. **Ceremony Initialization:** A standard Vultisig 2-of-3 signing ceremony is initiated across authorized devices.
2. **Context String:** The devices cooperatively sign a fixed, domain-separated message payload:

$$\sigma = \text{TSS-Sign}_{DKLS}(\text{"\x19Ethereum Signed Message:\n"} \parallel \text{len}(M) \parallel M)$$

\text{where } M = \text{"VULTISIG_SHIELDED_SUITE_DERIVATION_SALT_V1"}

3. **Key Expansion via HKDF:** Using RFC 5869 (HKDF with SHA-256):

$$PRK = \text{HKDF-Extract}(\text{Salt} = \text{"Vultisig-ZK-Salt"}, \text{IKM} = \sigma)$$

sk_{spend} = \text{HKDF-Expand}(PRK, \text{"SPENDING_KEY"}, 32) sk_{view} = \text{HKDF-Expand}(PRK, \text{"VIEWING_KEY"}, 32)

4. **Public Key Derivation on BabyJubJub Curve:** For compatibility with Circom/SnarkJS snark circuits:

$$pk_{view} = sk_{view} \cdot G_{\text{BabyJubJub}}$$

4.2 Shielded Note & Commitment Structure

All shielded balances inside the pool are represented as UTXO notes over the BN254 (alt_bn128) elliptic curve:

```
struct ShieldedNote {
    asset_id: u256,       // ERC-20 contract address (e.g., Base.USDC)
    amount: u64,          // Token amount (atomic units)
    owner_pk: [u8; 32],   // BabyJubJub public key of recipient
    rho: [u8; 32],        // Nullifier uniqueness seed
    r: [u8; 32],          // Blinding factor for hiding commitment
}
```

- **Note Commitment:**

$$C = \text{Poseidon5}(\text{asset_id}, \text{amount}, \text{owner_pk}, \text{rho}, \text{r})$$

- **Merkle State:** Commitments are appended to an on-chain **Incremental Merkle Tree** of depth 32 maintained inside the L2 smart contract.
- **Nullifier Computation:** To prevent double-spending without revealing which note was spent:

$$\text{Nullifier} = \text{Poseidon3}(sk_{spend}, \text{rho}, \text{commitment_index})$$

4.3 Dual-Recipient Encryption Protocol

When transferring within the shielded pool, the sender generates two encrypted ciphertexts using asymmetric ElGamal encryption on BabyJubJub:

- **Ciphertext A (Recipient):**

$$C_{rec} = \text{BabyJubJub-ElGamal-Encrypt}(pk_{view_recipient}, \text{Note})$$

- **Ciphertext B (Compliance Gateway):**

$$C_{comp} = \text{BabyJubJub-ElGamal-Encrypt}(pk_{compliance_gateway}, \text{Note})$$

The ZK Proof of Equivalence Circuit

The circuit validates the following constraints in zero-knowledge:

1. C_{rec} and C_{comp} encrypt the exact same $(\text{asset_id}, \text{amount}, \text{rho})$.
2. The commitment C is correctly computed from the decrypted note attributes.
3. The spender possesses the valid sk_{spend} corresponding to the spent note's commitment.
4. The spent note exists within the Merkle tree of root R.

5. The spent note commitment belongs to the pre-approved **Clean Association Set** (excluding sanctioned actors).

```
Public Inputs:
├── Merkle Root (R)
├── Nullifier
├── Ciphertext_Recipient
├── Ciphertext_Compliance
└── Compliance Gateway Public Key (pk_compliance)

Private Inputs:
├── Note details (asset_id, amount, rho, r)
├── sk_spend
├── Merkle Path & Index
└── Blinding factors for ElGamal encryptions
```

4.4 The "ReadOnly" Auditor Interface (0/3 Signing Power)

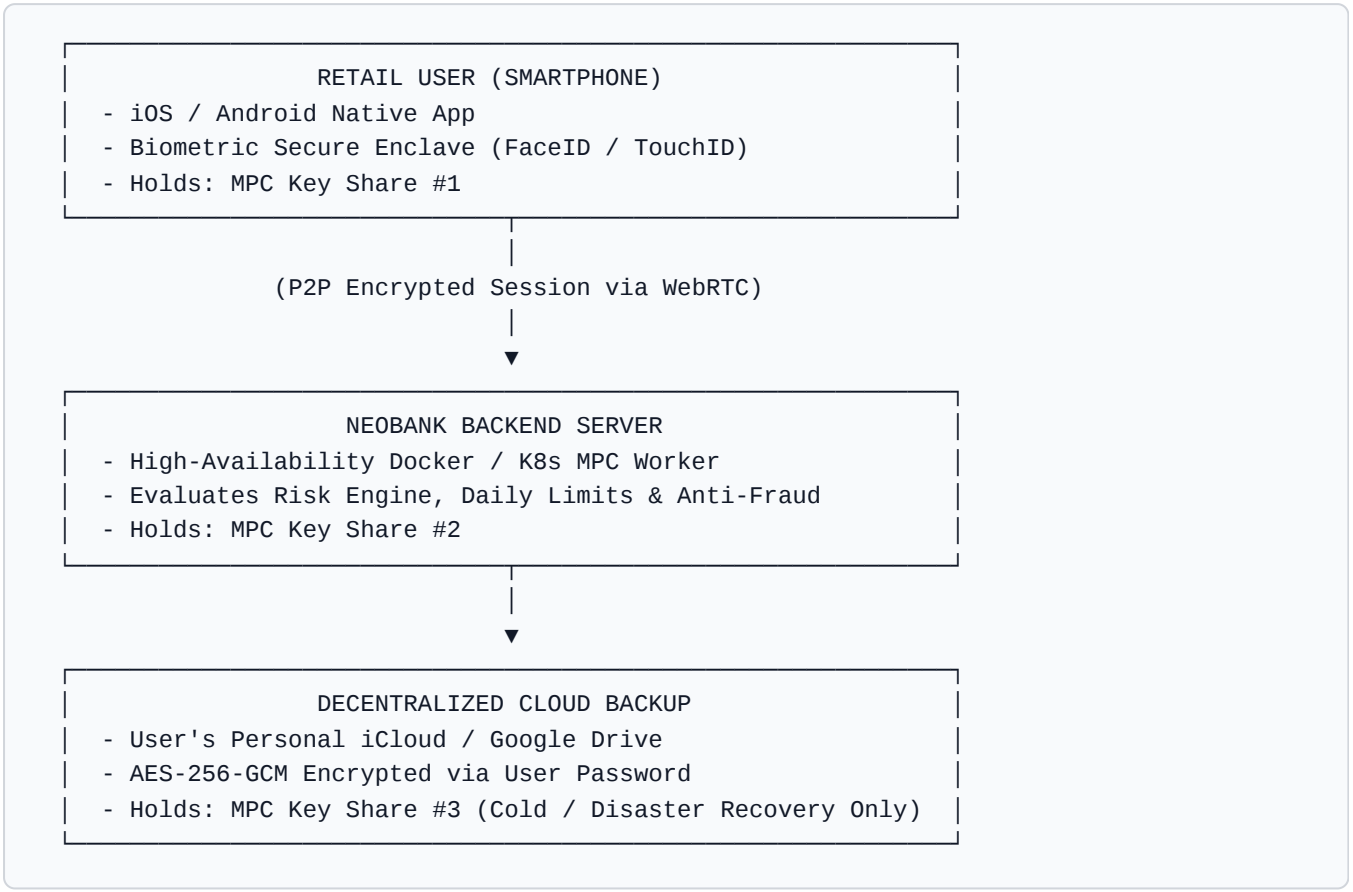
1. **Profile Export:** The enterprise exports a JSON payload containing sk_{view} and the gateway attestation identifier.
2. **Auditor Client:** The auditor (PwC, internal compliance, tax inspector) loads this profile into an **Auditor-Mode Vultisig Desktop/Web Client**.
3. **Deterministic Decryption:** The auditor client scans the on-chain event logs of the shielded contract:

$$\text{For each } C_{rec} \text{ in BlockRange: Attempt Decrypt with } sk_{view}$$

4. **Instant Audit Report:** Successfully decrypted notes reconstruct the full transaction journal:
   - Timestamp, counterparty public identifier, exact USDC amount, invoice reference memo.
   - **Security Guarantee:** sk_{view} is mathematically incapable of generating nullifiers or computing threshold DKLS signatures. The auditor has **read-only access**. Even if the auditor's machine is seized or compromised, treasury funds remain completely unspendable.

---

5. Turnkey Neobank WaaS: The "Grandma-Friendly" MPC Architecture



5.1 Three-Party Threshold Breakdown (2-of-3 FastVault)

- **Share 1 (User Device):** Generated in the local device runtime via `@vultisig/lib-dkls` (compiled to WebAssembly / Mobile C-bindings). Key-material is secured in the iOS Secure Enclave / Android KeyStore.
- **Share 2 (Neobank Server):** Maintained in a hardened Hardware Security Module (HSM) or secure cloud enclave. The server will only participate in an MPC signing ceremony if the user passes 2FA, biometric push, and velocity checks.
- **Share 3 (Disaster Recovery):** Encrypted using a password known only to the user and saved to their personal cloud storage. It is never accessed during day-to-day operations.

5.2 Key Resharing on Device Loss (Zero Loss, Zero Fund Movement)

Traditional seedless wallets face catastrophic failure if a device is destroyed without a seed backup. In this architecture:

1. User loses their phone.
2. User installs the Neobank app on a new device and completes Tier-2 Identity Verification (e.g., biometric selfie match against passport database).

3. The Neobank authenticates the user and authorizes an **MPC Resharing Protocol** (supported natively by DKLS23):
    - **Active Quorum:** Neobank Server (Share 2) + Disaster Cloud Backup (Share 3).
    - **Output:** A new Share 1 is generated and installed on the new device.
    - **Invalidation:** The old Share 1 on the lost device is mathematically invalidated.
4. **Key Benefit:** The blockchain wallet address (Base/Arbitrum) **does not change**. Assets are not transferred, triggering zero tax events and zero network transaction fees.

5.3 Gasless Account Abstraction (Paymaster Integration)

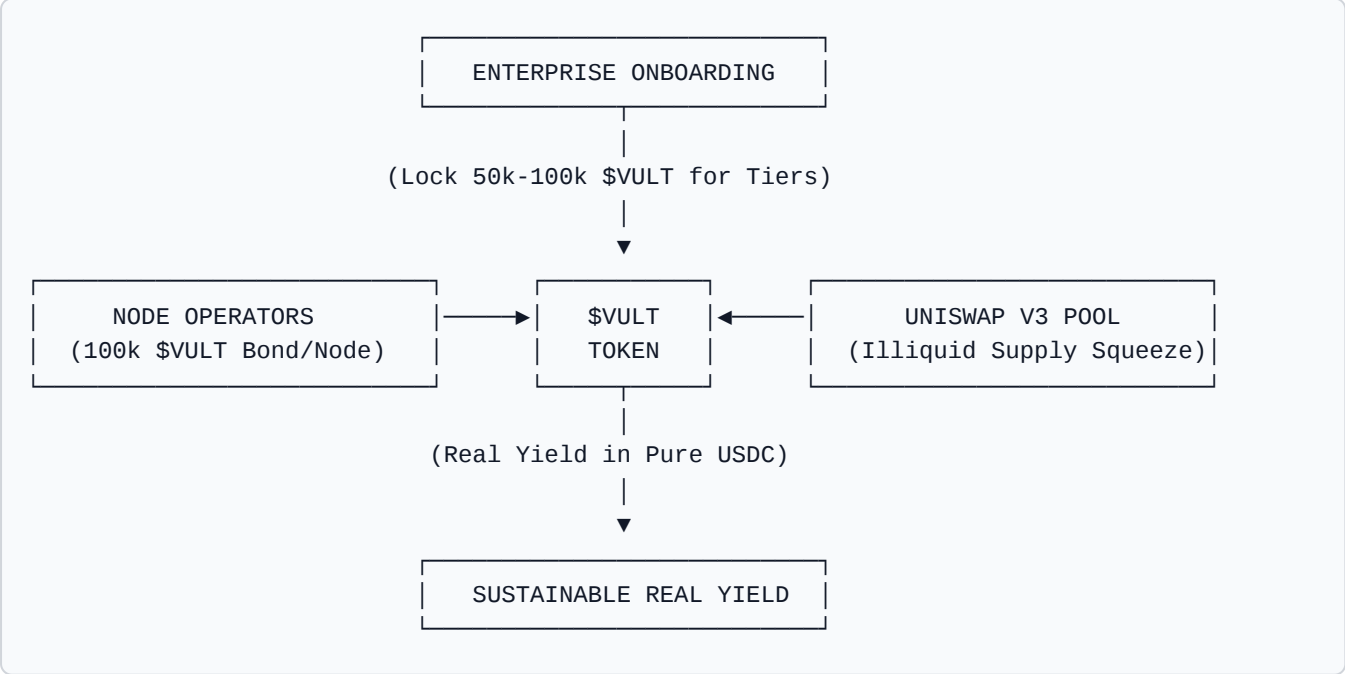
The user holds only stablecoins (e.g., Base.USDC). They never buy ETH for gas:

- The transaction is wrapped as an ERC-4337 UserOperation or routed via an MPC Gas Relay.
- The neobank sponsors the negligible L2 gas fee ($0.001 on Base) or automatically deducts a $0.05 fee directly in USDC.
- **UX Result:** The user opens the app, enters "Send $20 to Maria", confirms with FaceID, and the transfer settles in 1 second.

---

6. The $VULT Tokenomics Engine: Multi-Sided Supply Squeeze

The protocol converts enterprise privacy and B2B transaction volume into structural demand for the native $VULT token.



6.1 Bonded Privacy Nodes (Decentralized Coprocessors)

To route shielded transactions, aggregate zero-knowledge proofs, and maintain state synchronization between L2 shielded pools and the Vultisig client, operators run lightweight **Privacy Routing Nodes**:

- **Bond Requirement:** 100,000 $VULT locked in an on-chain staking contract on Arbitrum/Base.
- **Slashing Conditions:**
  - Offline penalty (downtime > 5% in an epoch): 0.5% bond burn.
  - Invalid state propagation or censorship attempt: 10% bond slashing.
- **Real Yield Mechanism:** 50% of all protocol privacy fees (collected in USDC/USDT) are distributed directly to active bonded node operators pro-rata.

6.2 Enterprise Fee-Reduction Locks

B2B volume follows a strict fee schedule designed to incentivize corporate token locking:

- **Standard Tier (Zero Lock):** 1.00% protocol fee per shielded settlement.
- **Tier 1 (Lock 50,000 $VULT):** 0.50% protocol fee per shielded settlement.
- **Tier 2 (Lock 100,000 $VULT):** 0.20% protocol fee + Dedicated Compliance Dashboard & Priority Routing.

6.3 Mathematical Supply Squeeze Model

Assume conservative mid-term adoption:

- **Active Corporate Clients:** 250 enterprises (averaging $200k/month in payroll and vendor disbursements).
- **Active Network Nodes:** 200 nodes securing the decentralized relay network.

$$\text{Tokens Locked by Enterprises} = 250 \times 50{,}000 = 12{,}500{,}000 \text{ \$VULT}$$

$$\text{Tokens Locked by Nodes} = 200 \times 100{,}000 = 20{,}000{,}000 \text{ \$VULT}$$

$$\text{Total Circulating Supply Removed} = 32{,}500{,}000 \text{ \$VULT } (\mathbf{32.5\%} \text{ of Total 100M Cap})$$

Because $VULT liquidity on Uniswap V3 is concentrated within narrow price bands, the programmatic withdrawal of 32.5% of total supply from the open market creates an inelastic supply curve, generating massive upward price reflexivity.

---

7. Comparative Technical Benchmark

Feature	Safe (Gnosis)	Fireblocks	MPCVault	Tornado Cash	Vultisig Enterprise
Cryptographic Scheme	Smart Contract Multi-Sig	MPC (Cloud Enclaves)	3-of-3 MPC (Azure/GCP)	Single Private Key	**Decentralized DKLS TSS**
On-Chain Anonymity	None (Public)	None (Public)	None (Public)	High (Tainted)	**High (Compliant ZK)**

Feature	Safe (Gnosis)	Fireblocks	MPCVault	Tornado Cash	Vultisig Enterprise
Auditing Protocol	Public Explorer	SaaS DB Logs	SaaS DB Logs	None (Mixer)	**Dual-Recipient ZK View-Keys**
Sanctions Screened	Front-end only	Centralized API	Centralized API	None (Toxic)	**On-Chain Proof of Innocence**
Regulatory Status	Neutral	Heavy Licensee	Heavy Licensee	Sanctioned / OFAC	**Exempt Non-Custodial Software**
Cross-Chain Breadth	EVM Only	Multi-Chain	Multi-Chain	EVM Only	**Native Multi-Chain (BTC, SOL, EVM)**
Turnkey Neobank WaaS	No (Too complex)	Enterprise Only	Enterprise Only	No	**Native FastVault 2-of-3 SDK**

---

8. Capital Efficiency, Open-Source Map & $70k Bootstrapped Runway

A fundamental misconception among blockchain executives is that implementing ZK-Shielded Pools requires millions of dollars in R&D. In reality, **over 85% of the complex cryptographic code is already battle-tested and open-source on GitHub**.

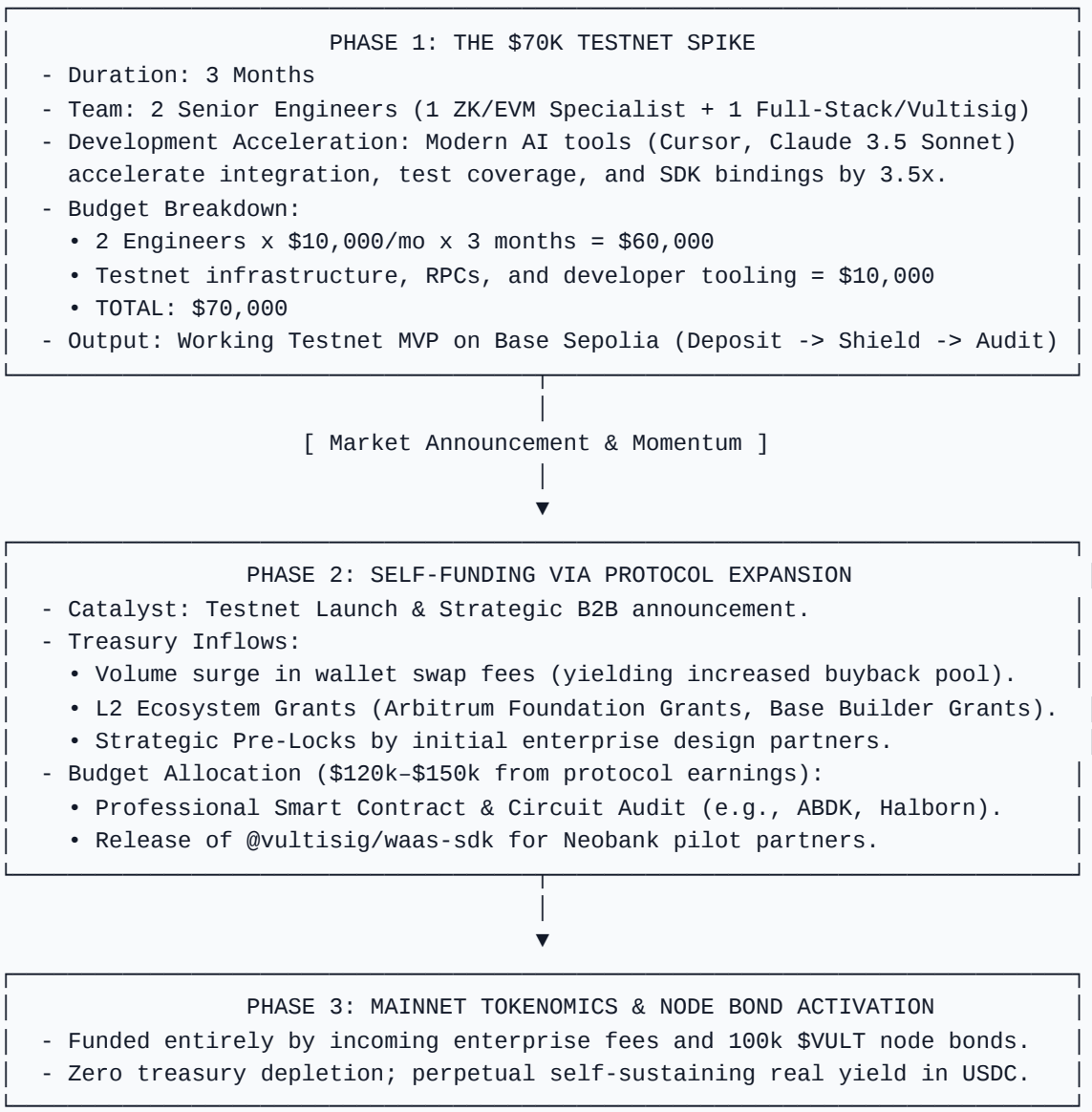
8.1 Open-Source Cryptographic Asset Map

Functional Layer	Battle-Tested Open-Source Repository	License	Implementation Role
Shielded Pool Smart Contracts	railgun-privacy/contract	MIT	Audited EVM contracts (Trail of Bits, ABDK) managing Merkle trees, nullifiers, and token vaults.
Proof of Innocence Circuits	ameensol/privacy-pools & 0xbow-io	MIT	Circom circuits proving membership in clean association sets (Vitalik's paper).
ZK Math & Primitives	iden3/circomlib & snarkjs	GPL-3.0 / MIT	Poseidon hash, BabyJubJub curve operations, and client-side proof generation.

Functional Layer	Battle-Tested Open-Source Repository	License	Implementation Role
On-Chain Attestations	ethereum-attestation-service/eas-contracts	MIT	Standardized contract infrastructure for licensed gateway KYB passes.
Threshold Core (TSS)	vultisig/lib-dkls & @vultisig/sdk	Apache-2.0	Vultisig's existing WASM-compiled DKLS23 engine.

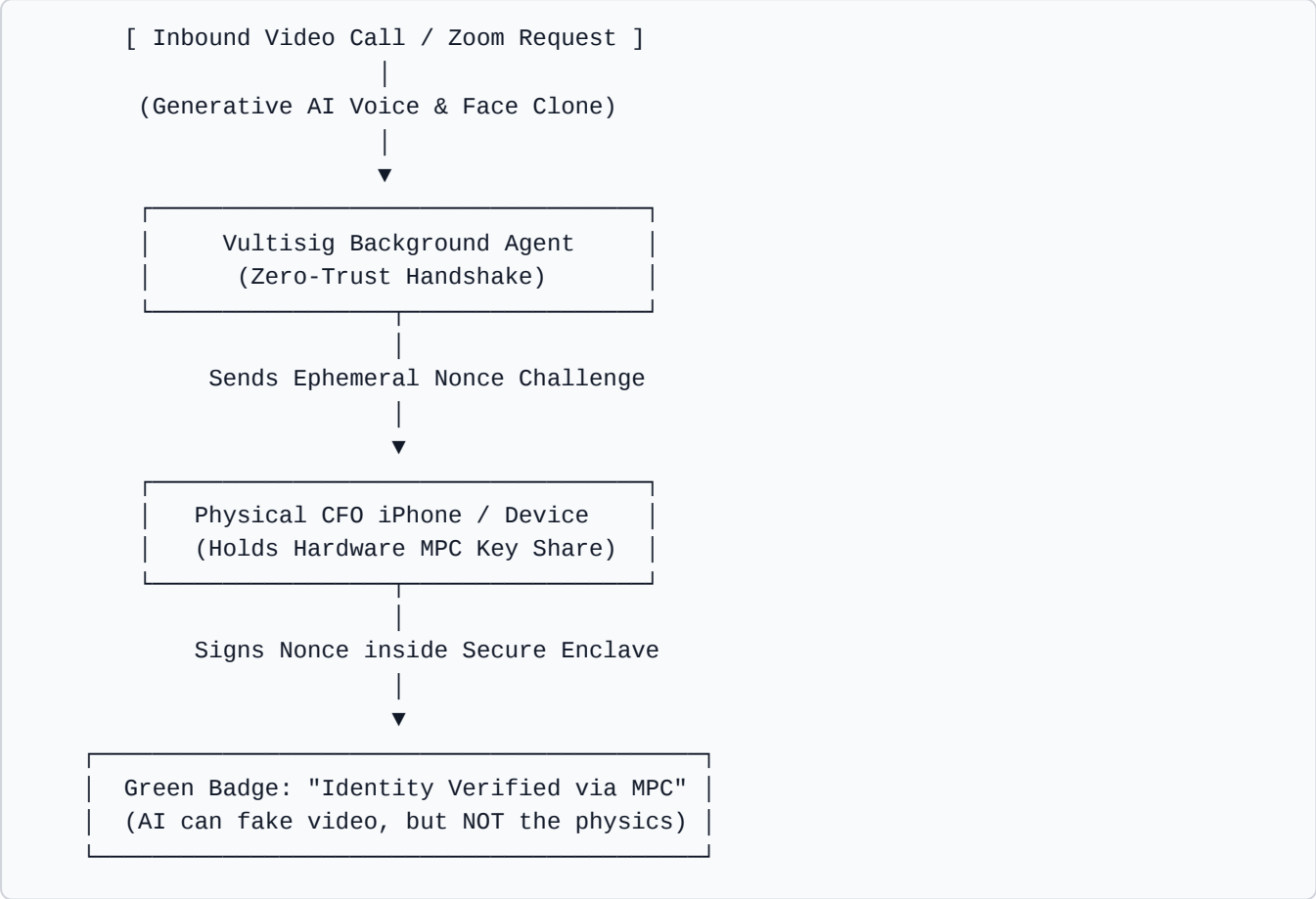
8.2 The Phased $70k Bootstrapped Self-Funding Model

Vultisig currently possesses approximately **$70,000 in liquid operational treasury**. This is more than sufficient to execute a high-impact **Phase 1 Testnet Spike**, creating the market momentum required to self-fund subsequent phases.



9. Strategic Horizon: Beyond Payments — Zero-Trust Identity & Anti-Deepfake Protocol

Vultisig's underlying technology is not merely a financial transfer mechanism—it is a **decentralized, threshold-secured cryptographic identity layer**. In an era where Generative AI has destroyed the trustworthiness of audio and video communications, Vultisig possesses the exact mathematical architecture to secure corporate communications and critical data assets.



9.1 Anti-Deepfake Voice & Video Authentication

Recent high-profile exploits (such as the high-profile impersonation attacks against crypto leaders and the $25 Million Hong Kong multinational video-conference deepfake fraud) demonstrate that visual and vocal identification is obsolete.

- **The Problem:** Attackers use real-time voice synthesis and video deepfakes to impersonate executives, authorizing fraudulent transfers or requesting emergency credentials.
- **The Vultisig MPC Solution:** An ephemeral, client-side zero-knowledge challenge-response protocol integrated into corporate communication tools (Slack, Zoom, Google Meet).
  1. When an executive initiates an operational request or executive video call, the caller's desktop client broadcasts an ephemeral cryptographic challenge (nonce).
  2. The executive's smartphone—holding an isolated Vultisig MPC share in its hardware Secure Enclave—prompts a silent biometric approval (FaceID).

3. The device signs the nonce off-chain and returns the cryptographic proof.
4. The receiver's screen displays an immutable **"Identity Verified via Physical MPC Hardware"** badge.

- **Why Attackers Fail:** Generative AI can clone pixels and audio frequencies, but it cannot synthesize an off-chain cryptographic signature from a physical hardware enclave located miles away.

9.2 Threshold-Encrypted Enterprise Data Vaults

Beyond financial transactions, global institutions face catastrophic liabilities from cloud database breaches and compromised storage repositories.

- **Decentralized Data Sharding:** Sensitive corporate assets (trade secrets, M&A agreements, intellectual property) are encrypted using a 2-of-3 threshold encryption scheme.
- **Zero Single Point of Breach:** One key share resides with the employee, one with the company's internal compliance server, and one in an offline recovery enclave.
- **Breach Immunity:** Even if an attacker completely compromises the enterprise's AWS cloud or internal file servers, the stolen files are mathematically indistinguishable from random noise. Decryption requires a live, policy-governed MPC quorum across physical devices.

---

10. Concrete Engineering Implementation Roadmap

```
PHASE 1: Core ZK-Module, Key Derivation & Testnet MVP (Months 1–3) [$70k Budget]
├── [Core] Integrate BabyJubJub curve & Poseidon hash into @vultisig/lib-dkls (WASM).
├── [DKLS] Implement deterministic derivation: HKDF(TSS-Sign("VULTISIG-AUDIT-v1")) ->
(sk_spend, sk_view).
├── [Contracts] Fork & deploy audited Circom Groth16 shielded contracts on Base Sepolia.
├── [Client] Build "Export Audit Package" & "Auditor View-Only Mode" into Vultisig
Desktop.
└── [Milestone] Live Testnet Demo & Public Strategic Announcement.

PHASE 2: Audits, Compliance Gateways & Neobank WaaS SDK (Months 4–6) [Self-Funded]
├── [Security] Contract third-party audit (ABDK / Trail of Bits / Halborn) funded via
grants/fees.
├── [Circuits] Deploy Dual-Recipient Encryption verification circuits.
├── [Contracts] Integrate Ethereum Attestation Service (EAS) verifier for Whitelist
Gateways.
├── [WaaS] Package @vultisig/waas-sdk for iOS/Android (Biometric Secure Enclave +
FastVault).
└── [Pilots] Onboard 3 licensed compliance partners (US/EU) & 2 regional neobanks.

PHASE 3: Node Network, Token Mechanics & Mainnet Launch (Months 7–9) [Node-Funded]
├── [Staking] Deploy 100k $VULT Node Staking & Slashing contracts on Base/Arbitrum.
├── [Relayers] Release lightweight Go/Rust daemon for bonded node operators.
├── [Tiers] Implement fee-tier deduction logic based on on-chain locked $VULT balance.
└── [Revenue] Activate automated USDC Real Yield distribution to active node operators.
```

---

11. Conclusion: The Strategic Path Forward

The Web3 market does not need another retail DEX aggregator or another basic crypto wallet. The retail market is saturated and low-margin.

By building the **first legal, compliant, B2B-ready privacy and WaaS framework**, Vultisig can solve the multi-trillion dollar commercial data leak problem, capture high-volume corporate payrolls, and transform the $VULT token from a speculative asset into a mission-critical infrastructure yield engine.

The technical foundations exist:

- The cryptographic blueprints are open-source and audited.
- The team has the necessary $70,000 runway to deliver a working Phase 1 Testnet MVP.
- The market narrative and subsequent fee revenue will organically fund the path to Mainnet.

Recommended Action for Core Leadership: Authorize the Phase 1 90-day technical sprint: fork the open-source circuits, implement the deterministic viewing-key derivation in `@vultisig/lib-dkls`, and execute the first shielded corporate payroll on Base Sepolia.